Auditoría independiente de AI-BUSINESS-OS

18 de octubre de 2026 · Evaluación técnica, estratégica y comercial

Revisé primero el documento de cambios del 18 de octubre y después el estado público del repositorio:

- Repositorio AI-BUSINESS-OS
- Resumen de cambios del 18/10/2026
- README y progreso declarado

Mi criterio es separar cuatro cuestiones que suelen confundirse: que el código funcione, que el sistema sea seguro, que resuelva un problema real y que alguien esté dispuesto a pagar por él.

1. Veredicto ejecutivo

El proyecto tiene una hipótesis comercial interesante, pero todavía no demuestra ser un producto empresarial vendible.

Avance técnico

Hay una base de orquestación y gobernanza que merece evaluarse.

Madurez comercial

Faltan integraciones reales, API implementada y validación con clientes.

Seguridad en producción

No debe darse por demostrada solamente por los tests o por bloquear código sospechoso.

Conclusión provisional: es más que una idea documentada, pero todavía está en la etapa de prototipo de infraestructura. No hay evidencia pública suficiente para afirmar que ya sea un negocio validado.

El cambio más importante que informa el documento es el paso de una gobernanza parcialmente declarativa a controles que supuestamente intervienen de verdad: auditoría con bloqueo por defecto, aplicación del presupuesto, aprobaciones persistentes y comandos para gestionarlas. También informa 111 tests aprobados y una ejecución automática que bloqueó una propuesta de código por considerarla peligrosa.


GitHub
+1

Eso es progreso real si se reproduce en el código y en pruebas independientes. Sin embargo, una prueba que demuestra que el sistema bloqueó un caso concreto no demuestra que detecte todos los casos peligrosos ni que sea seguro frente a entradas maliciosas.

Mi recomendación inicial: no abandonar el proyecto ni ampliar sus siete agentes por ahora. Primero hay que comprobar los límites de seguridad y elegir un problema comercial concreto que podamos resolver mejor que las alternativas.

2. Hallazgos técnicos: los cambios no están completamente cerrados

La inspección del código publicado revela problemas importantes que no aparecen con la misma claridad en el resumen de cambios. Estos son los hallazgos más relevantes de esta auditoría estática. No he ejecutado el proyecto ni reproducido las 111 pruebas en un entorno independiente, por lo que no voy a presentar esto como una certificación de seguridad.

Hallazgo crítico para la promesa de gobernanza: presupuesto incompleto

Prioridad P0

En `src/orchestrator/budget.py` existen límites para intentos, tiempo y costo. Sin embargo, en `agent_runner.py`, el control previo a la ejecución consulta `puede_reintentar()`, que verifica los intentos, pero no comprueba en ese punto `puede_continuar()`. Tampoco veo en el flujo publicado una aplicación efectiva del límite de tiempo y del costo acumulado antes de permitir que continúe.

Tener métodos para calcular límites no equivale a hacerlos cumplir. Esto contradice parcialmente la afirmación de que el presupuesto completo se aplica en cada llamada.


GitHub
+1

Hallazgo crítico para la continuidad: reanudación incompleta

Prioridad P0

En `AgentRunner.reanudar_flujo()`, el código verifica la aprobación y la consume, pero después devuelve el flujo con estado `en_progreso_reanudado`. El propio código comenta que falta continuar los pasos pendientes.

Por lo tanto, el mecanismo de reanudación todavía no demuestra que un flujo interrumpido pueda retomarse correctamente. La aprobación persistente puede funcionar mientras que la operación que debía autorizarse no se reanuda.


GitHub
+1

Hallazgo alto: aprobaciones persistentes, pero sin garantía de integridad completa

Prioridad P1

`approvals.py` sí utiliza un archivo JSON y escritura temporal con `os.replace`, lo cual es una mejora. Pero también captura errores de escritura y los ignora. Además, cuando la lectura del archivo falla, devuelve un estado vacío.

Esto puede ocultar un problema de persistencia o dejar solicitudes sin el estado esperado. No veo en este módulo autenticación del aprobador, bloqueo para escrituras concurrentes ni una garantía transaccional entre procesos. La atomicidad de un reemplazo de archivo no resuelve por sí sola esos problemas.


GitHub

Hallazgo alto: el auditor de IA no sustituye un control de seguridad determinista

Prioridad P1

`agent_runner.py` pasa el resultado de cada agente al Auditor y bloquea cuando este no aprueba o genera una excepción. Eso es una buena defensa adicional.

Sin embargo, la decisión de un agente basado en un modelo puede ser inconsistente. Detectar cadenas como `eval`, `exec` o `subprocess.run` no basta para demostrar que el código sea malicioso o inocuo. El control debería combinar reglas verificables, aislamiento real de procesos, permisos del sistema operativo y pruebas adversariales.


GitHub
+1

Hallazgo alto: la secuencia de siete agentes necesita validación de extremo a extremo

El flujo está definido en el código, pero una secuencia de siete roles no demuestra por sí sola que los resultados de cada etapa se transfieran correctamente a la siguiente. En particular, el flujo llama al Developer con una descripción de tarea, no con un mecanismo explícito de ejecución aislada visible en ese tramo.

El resumen del proyecto ya reconoce que las auditorías internas pueden bloquearse al llegar al Developer. Antes de añadir conectores reales, hay que resolver ese comportamiento sin debilitar la protección.


GitHub
+1

Mi interpretación

La buena noticia es que los problemas son identificables y corregibles. La mala noticia es que afectan precisamente al atributo que podría diferenciar el producto: la promesa de ejecutar tareas bajo control.

No recomiendo anunciar todavía «ejecución empresarial segura y autónoma». Una descripción más defendible sería: prototipo de orquestación multiagente con controles de gobernanza en desarrollo.

Qué pruebas faltan para cerrar esta parte

Prueba	Resultado exigido
Presupuesto	La tarea se detiene antes de superar el costo o tiempo configurado.
Reanudación	Una aprobación permite continuar desde el paso correcto, sin repetir operaciones previas.
Persistencia	Los errores de lectura/escritura se informan y bloquean cuando corresponde.
Identidad	Solo una persona autorizada puede aprobar una acción.
Seguridad	Código adversarial no puede escapar del aislamiento ni modificar archivos protegidos.
Regresión	Las pruebas existentes y las nuevas pasan en un entorno limpio.

Estas son pruebas de aceptación, no tareas que deban darse por resueltas por el mero hecho de añadir más tests.

3. ¿Es un pasatiempo o puede ser rentable?

Mi evaluación es que puede convertirse en un negocio, pero la rentabilidad depende mucho más del problema que resuelva que del número de agentes que tenga.

Evaluación comercial preliminar

Estimación cualitativa basada en el repositorio público, no en ventas ni entrevistas con clientes.

Valor como proyecto de aprendizaje
Alto
Potencial como herramienta para desarrolladores

Medio-alto
Potencial como servicio para empresas
Medio
Preparación actual para vender a empresas
Baja
Demanda comercial comprobada
Sin evidencia

El repositorio figura públicamente con cero estrellas y cero forks en la vista consultada. Eso no demuestra que el proyecto carezca de valor, pero sí significa que todavía no hay señales públicas importantes de adopción comunitaria en GitHub.


GitHub

Tres modelos de negocio posibles

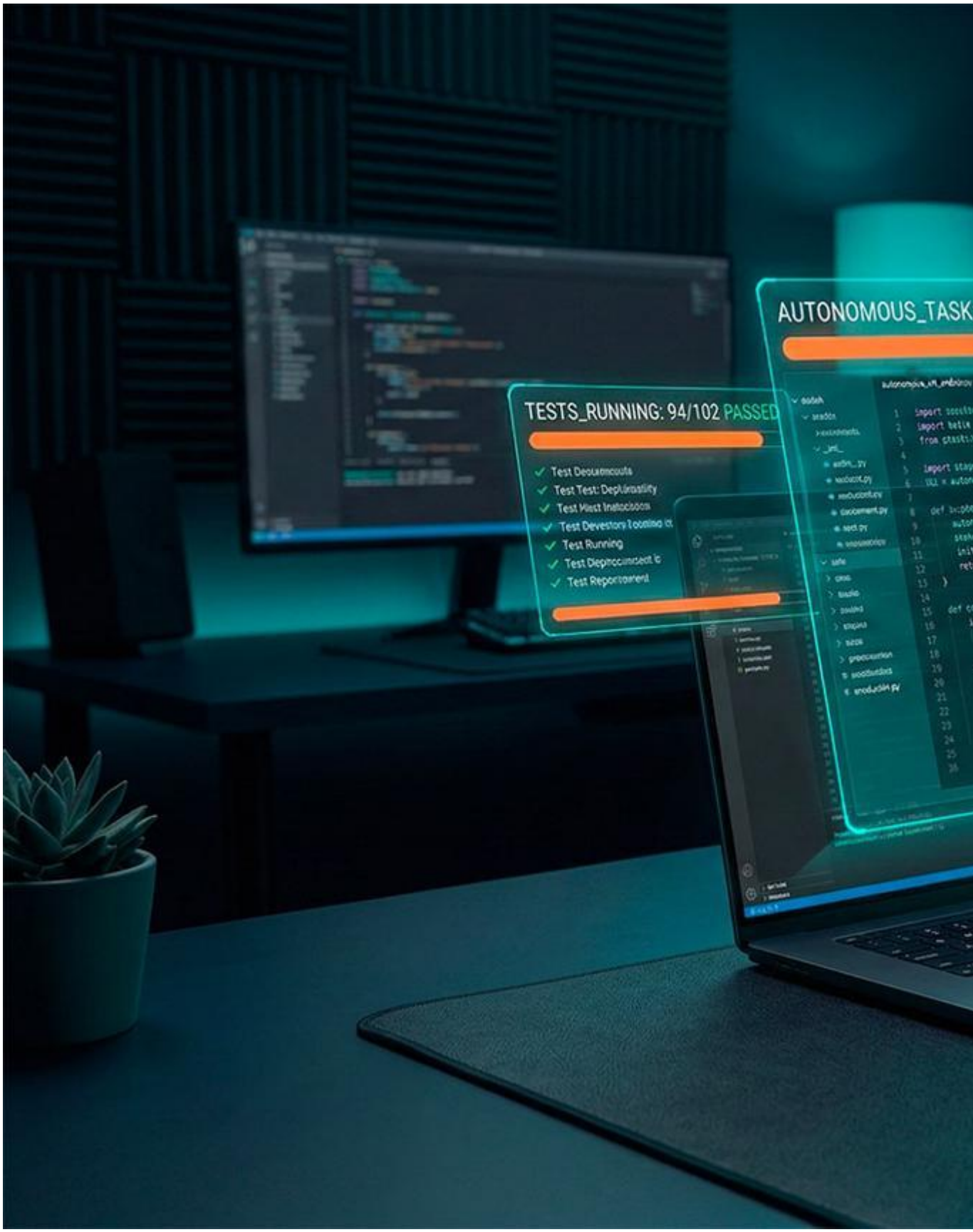


A. Automatización gestionada para pymes

Mi primera opción

Instalar y configurar automatizaciones para un negocio concreto, con registro de acciones, límites de gasto, aprobaciones y supervisión humana.

Cómo cobrar: implementación inicial más mantenimiento mensual. El cliente compra un resultado, no siete agentes.



B. Infraestructura de gobernanza para agentes

Vender el motor como biblioteca o servicio para equipos que ya usan agentes y necesitan controlar qué pueden hacer.

Cómo cobrar: licencia comercial, suscripción por uso o soporte empresarial. Requiere API estable, integración sencilla y evidencias de seguridad.



C. Simulador y auditor de decisiones empresariales

Permitir que una empresa pruebe escenarios, compare estrategias y genere informes de riesgos y costos antes de actuar.

Cómo cobrar: por informe, proyecto de consultoría o suscripción. El valor dependerá de que las simulaciones se aproximen a resultados reales.

Mi preferencia es comenzar con A, porque permite obtener ingresos antes de desarrollar una plataforma universal. Después, si el mismo mecanismo se reutiliza en varios clientes, convertir las partes comunes en un producto de software.

Un ejemplo económico ilustrativo

Supongamos un servicio de automatización para pymes, en dólares estadounidenses. Estos importes son escenarios de planificación, no precios de mercado verificados ni pronósticos.

Concepto mensual	Escenario ilustrativo
5 clientes a US$150	US$750
10 clientes a US$200	US$2.000
20 clientes a US$250	US$5.000

Son ingresos brutos recurrentes, antes de impuestos, infraestructura, modelos de IA, soporte, adquisición de clientes y horas de trabajo. La implementación inicial podría cobrarse aparte.

El indicador decisivo no sería alcanzar cierta facturación aislada, sino comprobar que cada cliente deja margen positivo y que el soporte no consume todo el ingreso.

4. ¿En qué ámbitos podría aplicarse?

Ámbito	Aplicación posible	Viabilidad actual
Desarrollo de software	Revisar cambios, ejecutar pruebas y pedir autorización antes de modificar archivos protegidos.	Alta como prototipo, tras corregir los controles.
Administración de pymes	Procesar tareas internas, generar informes y preparar operaciones para aprobación.	Buena oportunidad de piloto.
Agencias de marketing	Preparar campañas, validar contenidos y controlar acciones antes de publicar.	Viable con conectores y revisión humana.
Consultoría	Comparar escenarios, registrar decisiones y elaborar informes ejecutivos.	Viable si las simulaciones se validan.
Finanzas y operaciones críticas	Proponer conciliaciones o alertas, sin mover dinero automáticamente.	Requiere controles reforzados.

Salud, legal y sectores regulados	Asistencia documental con trazabilidad y supervisión especializada.	No recomendable como primer mercado.

El error sería intentar atender todos esos sectores al mismo tiempo. Cada uno tiene datos, integraciones, reglas y responsabilidades diferentes.

El primer mercado que probaría

Una empresa pequeña de servicios que tenga tareas repetitivas y claramente delimitadas: por ejemplo, recibir solicitudes, clasificarlas, preparar una respuesta, registrar el caso y solicitar autorización antes de enviarla.

El flujo tendría que demostrar tres cosas:

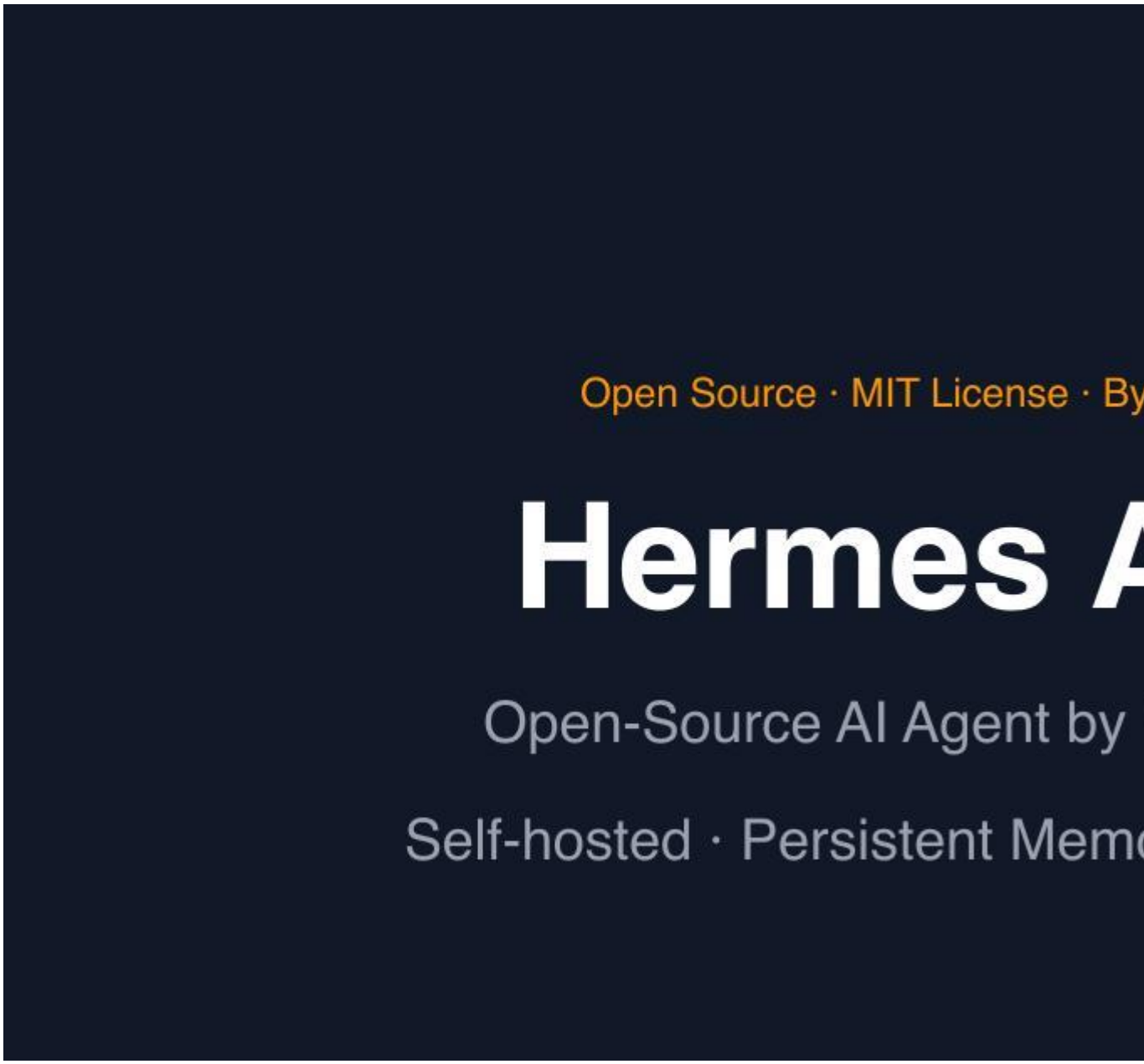
1. Reduce horas de trabajo medibles.
2. No realiza acciones externas sin permiso.
3. Permite reconstruir qué ocurrió, quién autorizó cada acción y cuánto costó.

Ese piloto generaría evidencia comercial y técnica al mismo tiempo.

5. AI-BUSINESS-OS frente a Hermes y los asistentes de IA

Primero, una distinción importante: Hermes Agent no es simplemente un chatbot. Su documentación describe un agente que puede utilizar herramientas, ejecutar comandos, automatizar tareas, mantener memoria y delegar trabajo a subagentes.

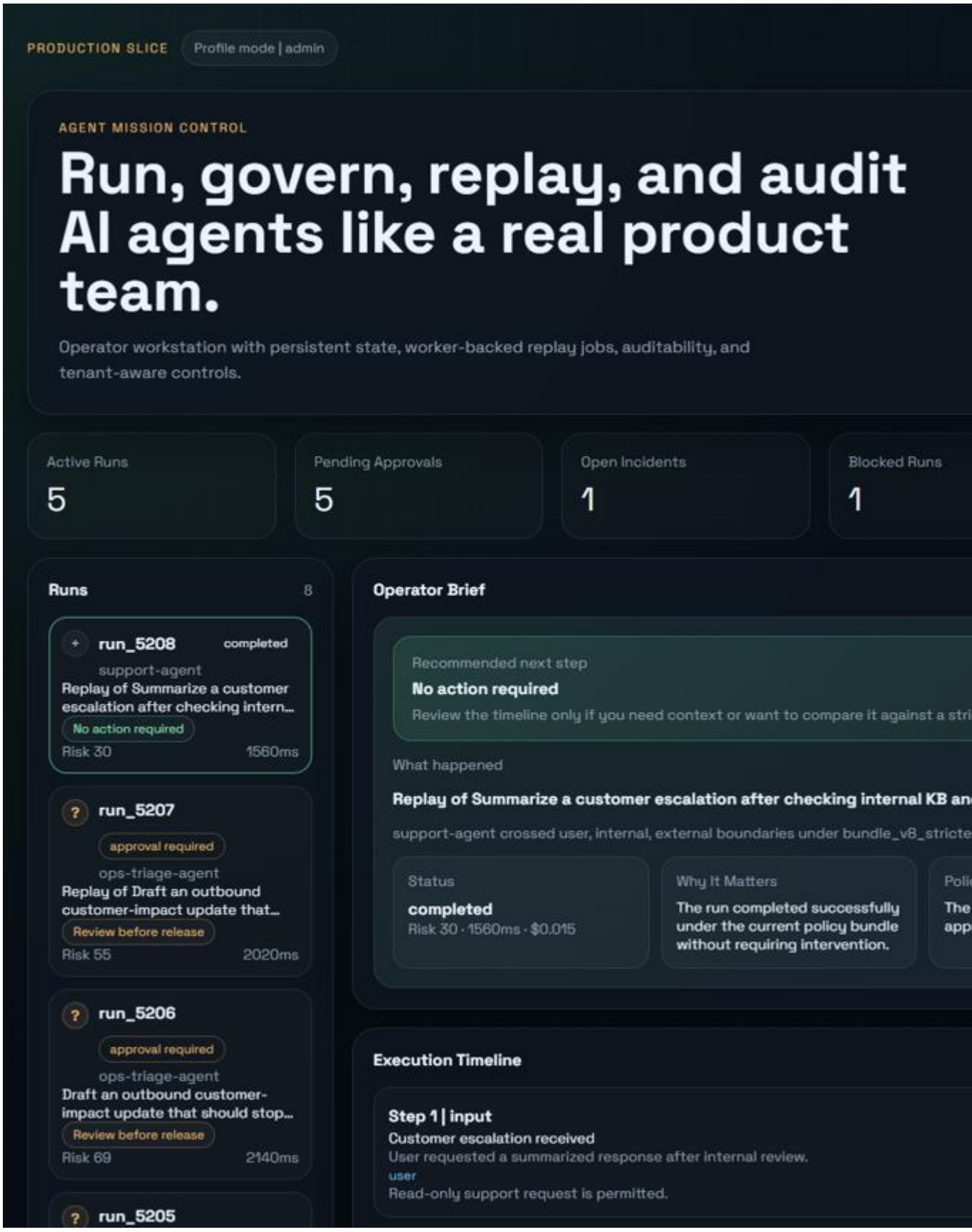

GitHub
+2



Hermes Agent

Es un agente ejecutor generalista. Su fortaleza es la interacción con herramientas, terminales, navegadores, memoria y canales de comunicación. Ya dispone de capacidades que AI-BUSINESS-OS todavía necesita desarrollar, como integraciones y automatizaciones más amplias.

GitHub
+1



AI-BUSINESS-OS

Aspira a ser una capa de ejecución gobernada: roles fijos, políticas, auditoría, límites y aprobaciones. Su propuesta no debería ser hacer más cosas que Hermes, sino hacer que las acciones de los agentes puedan someterse a controles verificables y políticas de una organización. Esa diferenciación es todavía una hipótesis por validar.



Asistentes generalistas: ChatGPT, Claude y Gemini

Son interfaces y plataformas de IA con capacidades que varían según el producto, el modelo y las herramientas conectadas. Pueden ayudar a planificar, analizar documentos y ejecutar acciones en entornos compatibles. Por eso, la afirmación del proyecto de que las IA generalistas «piensan pero no ejecutan» es demasiado amplia.


GitHub
+1

La comparación decisiva

Capacidad	Hermes Agent	AI-BUSINESS-OS actual
Asistencia y ejecución con herramientas	Sí	Parcial, orientado a flujos
Memoria persistente	Sí	Sí, basada en archivos
Agentes y delegación	Sí	Roles fijos definidos
Aprobaciones humanas	Dispone de mecanismos propios de control; deben compararse caso por caso.	Implementadas parcialmente; reanudación pendiente de corregir.
Límites de costo y tiempo	Depende de configuración y entorno	Declarados, pero su aplicación completa necesita corregirse.
API empresarial propia	Hermes documenta una API compatible con OpenAI en sus capacidades actuales.	OpenAPI conceptual; servidor real pendiente.
Seguridad empresarial demostrada	No se presume automáticamente	Tampoco está demostrada todavía

¿Cuál sería la estrategia inteligente?

No intentaría competir con Hermes construyendo otro asistente generalista.

Estudiaría la posibilidad de integrar AI-BUSINESS-OS como una capa de políticas y aprobación para Hermes y otros agentes, siempre que se compruebe que puede interceptar y controlar sus acciones de forma fiable.

La arquitectura deseada sería:

#chatgpt-mermaid-_r_10e_{font-family:-apple-system-body,ui-sans-serif,-apple-system,system-ui,"Segoe UI",Helvetica,"Apple Color Emoji",Arial,sans-serif,"Segoe UI Emoji","Segoe UI Symbol";font-size:16px;fill:rgb(237, 237, 237);}@keyframes edge-animation-frame{from{stroke-dashoffset:0;}}@keyframes dash{to{stroke-dashoffset:0;}}#chatgpt-mermaid-_r_10e_ .edge-animation-slow{stroke-dasharray:9,5!important;stroke-dashoffset:900;animation:dash 50s linear infinite;stroke-

linecap:round;}#chatgpt-mermaid-_r_10e_ .edge-animation-fast{stroke-dasharray:9,5!important;stroke-dashoffset:900;animation:dash 20s linear infinite;stroke-linecap:round;}#chatgpt-mermaid-_r_10e_ .error-icon{fill:rgb(48, 48, 48);}#chatgpt-mermaid-_r_10e_ .error-text{fill:rgb(237, 237, 237);stroke:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ .edge-thickness-normal{stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .edge-thickness-thick{stroke-width:3.5px;}#chatgpt-mermaid-_r_10e_ .edge-pattern-solid{stroke-dasharray:0;}#chatgpt-mermaid-_r_10e_ .edge-thickness-invisible{stroke-width:0;fill:none;}#chatgpt-mermaid-_r_10e_ .edge-pattern-dashed{stroke-dasharray:3;}#chatgpt-mermaid-_r_10e_ .edge-pattern-dotted{stroke-dasharray:2;}#chatgpt-mermaid-_r_10e_ .marker{fill:rgb(175, 175, 175);stroke:rgb(175, 175, 175);}#chatgpt-mermaid-_r_10e_ .marker.cross{stroke:rgb(175, 175, 175);}#chatgpt-mermaid-_r_10e_ svg{font-family:-apple-system-body,ui-sans-serif,-apple-system,system-ui,"Segoe UI",Helvetica,"Apple Color Emoji",Arial,sans-serif,"Segoe UI Emoji","Segoe UI Symbol";font-size:16px;}#chatgpt-mermaid-_r_10e_ p{margin:0;}#chatgpt-mermaid-_r_10e_ .label{font-family:-apple-system-body,ui-sans-serif,-apple-system,system-ui,"Segoe UI",Helvetica,"Apple Color Emoji",Arial,sans-serif,"Segoe UI Emoji","Segoe UI Symbol";color:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ .cluster-label text{fill:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ .cluster-label span{color:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ .cluster-label span p{background-color:transparent;}#chatgpt-mermaid-_r_10e_ .label text,#chatgpt-mermaid-_r_10e_ span{fill:rgb(237, 237, 237);color:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ .node rect,#chatgpt-mermaid-_r_10e_ .node circle,#chatgpt-mermaid-_r_10e_ .node ellipse,#chatgpt-mermaid-_r_10e_ .node polygon,#chatgpt-mermaid-_r_10e_ .node path{fill:rgb(9, 23, 44);stroke:rgb(31, 78, 148);stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .rough-node .label text,#chatgpt-mermaid-_r_10e_ .node .label text,#chatgpt-mermaid-_r_10e_ .image-shape .label,#chatgpt-mermaid-_r_10e_ .icon-shape .label{text-anchor:middle;}#chatgpt-mermaid-_r_10e_ .node .katex path{fill:#000;stroke:#000;stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .rough-node .label,#chatgpt-mermaid-_r_10e_ .node .label,#chatgpt-mermaid-_r_10e_ .image-shape .label,#chatgpt-mermaid-_r_10e_ .icon-shape .label{text-align:center;}#chatgpt-mermaid-_r_10e_ .node.clickable{cursor:pointer;}#chatgpt-mermaid-_r_10e_ .root .anchor path{fill:rgb(175, 175, 175)!important;stroke-width:0;stroke:rgb(175, 175, 175);}#chatgpt-mermaid-_r_10e_ .arrowheadPath{fill:rgb(175, 175, 175);}#chatgpt-mermaid-_r_10e_ .edgePath .path{stroke:rgb(175, 175, 175);stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .flowchart-link{stroke:rgb(175, 175, 175);fill:none;}#chatgpt-mermaid-_r_10e_ .edgeLabel{background-color:rgb(0, 0, 0);text-align:center;}#chatgpt-mermaid-_r_10e_ .edgeLabel p{background-color:rgb(0, 0, 0);}#chatgpt-mermaid-_r_10e_ .edgeLabel rect{opacity:0.5;background-color:rgb(0, 0, 0);fill:rgb(0, 0, 0);}#chatgpt-mermaid-_r_10e_ .labelBkg{background-color:rgba(0, 0, 0, 0.5);}#chatgpt-mermaid-_r_10e_ .cluster rect{fill:rgb(48, 48, 48);stroke:rgba(255, 255, 255, 0.15);stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .cluster text{fill:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ .cluster span{color:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ div.mermaidTooltip{position:absolute;text-align:center;max-width:200px;padding:2px;font-family:-apple-system-body,ui-sans-serif,-apple-system,system-ui,"Segoe UI",Helvetica,"Apple Color Emoji",Arial,sans-serif,"Segoe UI Emoji","Segoe UI Symbol";font-size:12px;background:rgb(48, 48, 48);border:1px solid rgba(255, 255, 255, 0.15);border-radius:2px;pointer-events:none;z-index:100;}#chatgpt-mermaid-_r_10e_ .flowchartTitleText{text-anchor:middle;font-

size:18px;fill:rgb(237, 237, 237);}#chatgpt-mermaid-_r_10e_ rect.text{fill:none;stroke-width:0;}#chatgpt-mermaid-_r_10e_ .icon-shape,#chatgpt-mermaid-_r_10e_ .image-shape{background-color:rgb(0, 0, 0);text-align:center;}#chatgpt-mermaid-_r_10e_ .icon-shape p,#chatgpt-mermaid-_r_10e_ .image-shape p{background-color:rgb(0, 0, 0);padding:2px;}#chatgpt-mermaid-_r_10e_ .icon-shape .label rect,#chatgpt-mermaid-_r_10e_ .image-shape .label rect{opacity:0.5;background-color:rgb(0, 0, 0);fill:rgb(0, 0, 0);}#chatgpt-mermaid-_r_10e_ .label-icon{display:inline-block;height:1em;overflow:visible;vertical-align:-0.125em;}#chatgpt-mermaid-_r_10e_ .node .label-icon path{fill:currentColor;stroke:revert;stroke-width:revert;}#chatgpt-mermaid-_r_10e_ .node .neo-node{stroke:rgb(31, 78, 148);}#chatgpt-mermaid-_r_10e_ [data-look="neo"].node rect,#chatgpt-mermaid-_r_10e_ [data-look="neo"].cluster rect,#chatgpt-mermaid-_r_10e_ [data-look="neo"].node polygon{stroke:url(#chatgpt-mermaid-_r_10e_-gradient);filter:drop-shadow(1px 2px 2px rgba(185,185,185,1));}#chatgpt-mermaid-_r_10e_ [data-look="neo"].swimlane.cluster rect{filter:none;}#chatgpt-mermaid-_r_10e_ [data-look="neo"].node path{stroke:url(#chatgpt-mermaid-_r_10e_-gradient);stroke-width:1px;}#chatgpt-mermaid-_r_10e_ [data-look="neo"].node .outer-path{filter:drop-shadow(1px 2px 2px rgba(185,185,185,1));}#chatgpt-mermaid-_r_10e_ [data-look="neo"].node .neo-line path{stroke:rgb(31, 78, 148);filter:none;}#chatgpt-mermaid-_r_10e_ [data-look="neo"].node circle{stroke:url(#chatgpt-mermaid-_r_10e_-gradient);filter:drop-shadow(1px 2px 2px rgba(185,185,185,1));}#chatgpt-mermaid-_r_10e_ [data-look="neo"].node circle .state-start{fill:#000000;}#chatgpt-mermaid-_r_10e_ [data-look="neo"].icon-shape .icon{fill:url(#chatgpt-mermaid-_r_10e_-gradient);filter:drop-shadow(1px 2px 2px rgba(185,185,185,1));}#chatgpt-mermaid-_r_10e_ [data-look="neo"].icon-shape .icon-neo path{stroke:url(#chatgpt-mermaid-_r_10e_-gradient);filter:drop-shadow(1px 2px 2px rgba(185,185,185,1));}#chatgpt-mermaid-_r_10e_ .node text{font-size:14px;font-weight:600;letter-spacing:normal;fill:rgb(153, 206, 255);}#chatgpt-mermaid-_r_10e_ .edgeLabels text{font-size:13px;font-weight:600;letter-spacing:-0.08px;fill:rgb(153, 206, 255);}#chatgpt-mermaid-_r_10e_ .node tspan[font-weight="normal"],#chatgpt-mermaid-_r_10e_ .edgeLabels tspan[font-weight="normal"]{font-weight:600;}#chatgpt-mermaid-_r_10e_ .edgeLabel .label rect{opacity:1;rx:13px;ry:13px;fill:rgb(0, 14, 26);stroke:rgb(26, 62, 95);stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .node rect,#chatgpt-mermaid-_r_10e_ .node circle,#chatgpt-mermaid-_r_10e_ .node ellipse,#chatgpt-mermaid-_r_10e_ .node polygon,#chatgpt-mermaid-_r_10e_ .node path{fill:rgb(0, 40, 77);stroke:rgba(255, 255, 255, 0.1);stroke-width:1px;}#chatgpt-mermaid-_r_10e_ .node rect{rx:16px;ry:16px;}#chatgpt-mermaid-_r_10e_ .node.mermaid-decision .label-container{fill:rgb(0, 14, 26);stroke:rgb(26, 62, 95);stroke-dasharray:2,2;}#chatgpt-mermaid-_r_10e_ .edgePaths .flowchart-link{stroke:rgb(175, 175, 175);stroke-width:1px;stroke-linecap:round;stroke-linejoin:round;}#chatgpt-mermaid-_r_10e_ .marker{fill:rgb(175, 175, 175);stroke:rgb(175, 175, 175);}#chatgpt-mermaid-_r_10e_ :root{--mermaid-font-family:-apple-system-body,ui-sans-serif,-apple-system,system-ui,"Segoe UI",Helvetica,"Apple Color Emoji",Arial,sans-serif,"Segoe UI Emoji","Segoe UI Symbol";}Hermes, ChatGPT u otroagenteSolicitud de acciónMotor de políticasAI-BUSINESS-OS¿Autorizada?Bloquear y registrarAprobación humanaautenticadaEjecutor aisladoVerificación del resultadoRegistro de auditoría y costosNoRequiere permisoSíAprobadaRechazada

Esta arquitectura es una propuesta, no una función que el repositorio ya implemente.

Para que sea una diferencia real, el motor de políticas debe controlar las acciones en el punto de ejecución. No alcanza con auditar la descripción de una tarea o inspeccionar el texto generado por un modelo.

6. Qué haría único a AI-BUSINESS-OS

La gobernanza por sí sola no es una ventaja competitiva suficiente. Otros proyectos también tienen herramientas, memoria, checkpoints, delegación y controles. La oportunidad está en convertir esos elementos en garantías comprobables y fáciles de usar.

Propongo cuatro características.

1. Contrato de ejecución verificable

Cada acción declara qué pretende hacer, qué recursos necesita, qué podría modificar, cuánto puede costar y qué aprobación requiere. El sistema verifica el contrato antes de ejecutarla y después comprueba el resultado.

Diferencial: pasar de «la IA dice que es segura» a «el sistema comprueba condiciones específicas».

2. Registro de auditoría reproducible

Guardar solicitud, política aplicada, identidad del agente, aprobación, versión del ejecutor, costos, resultado y motivo de cada bloqueo. Añadir protección contra alteraciones y herramientas para verificar los registros.

Diferencial: una empresa puede investigar qué sucedió sin depender de la memoria de una conversación.

3. Capa de control independiente del proveedor

Una interfaz común para aplicar políticas a agentes de diferentes modelos y plataformas. Empezar por una integración real y demostrar que todas las acciones pasan por los controles.

Diferencial: reducir la dependencia de un único proveedor de IA. Esto exige diseñar e implementar los conectores, no solo documentarlos.

4. Evidencia del valor económico

Medir tiempo ahorrado, costo por tarea completada, errores evitados, bloqueos correctos y porcentaje de tareas que requieren intervención humana.

Diferencial: vender una reducción de riesgo o costo demostrable, no una colección de agentes.

7. Problemas de posicionamiento que conviene resolver

La documentación presenta inconsistencias que pueden afectar la confianza de usuarios técnicos:

- El resumen de cambios informa 111 pruebas aprobadas, mientras el README mantiene una descripción del progreso fechada el 16 de octubre. Hay que sincronizar la fecha y los resultados.
- `VISION_B2AI.md` todavía presenta las etapas 4, 5 y 6 como pendientes, mientras el README las declara completadas.

  GitHub

  +1

- El manifiesto declara una API futura y un plugin futuro, y el archivo OpenAPI confirma que el servidor REST todavía no está implementado. No deben anunciarse como capacidades operativas.

  GitHub

  +1

- La documentación habla de un proyecto abierto, pero el README consultado no muestra una licencia inequívoca en su lista de archivos y OpenAPI declara MIT. Antes de distribuirlo comercialmente hay que aclarar la licencia real y los derechos sobre dependencias y componentes.

  GitHub

  +1

También cambiaría la estrategia B2AI. El manifiesto y la documentación dirigidos a otras IA pueden facilitar que un agente entienda el proyecto, pero no obligan a ChatGPT, Claude ni otros sistemas a descubrirlo, instalarlo o recomendarlo. La indexación y la recomendación son canales inciertos, no un modelo de adquisición de clientes suficiente.

La captación principal debería venir de casos de uso, demostraciones, documentación reproducible, integraciones y resultados publicados.

8. Plan de trabajo recomendado para las próximas dos semanas

No avanzaría directamente a la Etapa 7 de conectores reales. Primero cerraría los controles que sustentan la propuesta de valor.

Días 1–3

Fase 1 — Corregir la gobernanza

- Aplicar y comprobar los límites de tiempo y costo.
- Completar la reanudación real del flujo.
- Hacer que los errores de persistencia sean visibles.
- Revisar el punto donde se aplican los permisos.

Días 4–6

Fase 2 — Pruebas adversariales

- Probar evasiones de las reglas de código.
- Simular fallos del modelo auditor, archivos dañados y ejecuciones duplicadas.
- Verificar aislamiento real y protección de archivos.
- Repetir la suite de tests en un entorno limpio.

Días 7–9

Fase 3 — Primer caso de uso

- Elegir una única tarea de una pyme.
- Diseñar un flujo completo, inicialmente sin acciones irreversibles.
- Medir tiempo, costo, errores y aprobaciones.
- Comparar el resultado con el procedimiento manual.

Días 10–14

Fase 4 — Validación comercial

- Preparar una demostración reproducible.
- Presentarla a potenciales usuarios y recoger objeciones.
- Definir una oferta de piloto y un precio experimental.
- Decidir si conviene construir la API, un conector o un servicio gestionado.

Este calendario es una meta de planificación para un alcance acotado; no una garantía de finalización. El resultado de las pruebas podría exigir más tiempo.

9. Instrucciones para Codex: primera misión

Te dejo un prompt listo para usar. Está diseñado para evitar que Codex reescriba el proyecto, consuma recursos innecesariamente o declare resueltos problemas sin demostrarlo.

MISIÓN: AUDITORÍA TÉCNICA Y CIERRE DE GOBERNANZA — AI-BUSINESS-OS

Repositorio: `https://github.com/GustavoLozz/ai-business-os`

Objetivo

Verificar y corregir exclusivamente los defectos demostrables del motor de gobernanza antes de implementar API REST, MCP o conectores reales.

REGLAS OBLIGATORIAS

1. Empezá con una inspección de solo lectura.
2. No modifiques archivos en la fase de diagnóstico.
3. No borres datos, informes, memoria, checkpoints ni aprobaciones.
4. No instales dependencias ni hagas llamadas a servicios externos sin autorización.
5. No ejecutes acciones sobre cuentas reales ni expongas credenciales.
6. Conservá el diseño actual. No hagas refactorizaciones generales.
7. Antes de modificar código, presentá los hallazgos, los archivos afectados y el plan mínimo. Esperá autorización humana.
8. No declares una prueba aprobada si no se ejecutó y se verificó su resultado.

FASE A — DIAGNÓSTICO DE SOLO LECTURA

Inspeccioná:

- `src/orchestrator/agent_runner.py`
- `src/orchestrator/budget.py`
- `src/orchestrator/approvals.py`
- `src/orchestrator/permission_system.py`
- `src/agents/auditor.py`
- `GOVERNANCE.md`
- Los tests relacionados con esos módulos.

Verificá específicamente:

1. Si el presupuesto máximo de costo y tiempo se hace cumplir antes, durante y después de ejecutar una tarea.
2. Si todos los costos de llamadas a modelos se registran correctamente y no se permite superar el presupuesto por falta de contabilización.
3. Si `reanudar_flujo()` continúa realmente desde el paso pendiente, sin repetir operaciones previas ni saltarse controles.
4. Si las aprobaciones persisten ante reinicios, errores de escritura, archivos JSON inválidos y accesos concurrentes.

5. Si se comprueba la identidad y autorización de quien aprueba.
6. Si el control de permisos funciona de forma predeterminada restrictiva.
7. Si el Auditor puede ser evadido mediante estructuras de datos inesperadas, código ofuscado, rutas alternativas o instrucciones maliciosas.
8. Si el Developer está realmente aislado por controles del sistema operativo y no solo por una bandera o una convención del agente.
9. Si el flujo completo puede alcanzar un estado incorrecto aunque un paso esté bloqueado.
10. Si los tests existentes comprueban comportamiento real o solamente valores declarados.

FASE B — INFORME

Generá un informe con:

- Hallazgo y severidad.
- Archivo, función y líneas.
- Evidencia reproducible.
- Impacto real.
- Test que falta.
- Corrección mínima propuesta.
- Riesgo de regresión.
- Criterio de aceptación.

Separá los defectos confirmados de las hipótesis que todavía necesitan pruebas.

FASE C — ESPERA DE AUTORIZACIÓN

Al terminar el informe, detenete. No modifiques el código hasta recibir aprobación explícita.

FASE D — CORRECCIONES AUTORIZADAS

Una vez aprobadas:

- Realizá cambios pequeños y aislados.
- Añadí tests de regresión y pruebas adversariales.
- Ejecutá los tests pertinentes y después la suite completa.
- Informá los resultados reales.
- Conservá un diff claro y un checkpoint recuperable.
- No avances a API REST, MCP ni conectores reales en esta misión.

CRITERIO DE FINALIZACIÓN

La misión termina con un informe que distingue:

- Defectos corregidos y comprobados.
- Defectos pendientes.

- Pruebas ejecutadas y sus resultados.
- Riesgos residuales.
- Próximo paso recomendado.

No declares el sistema seguro para producción sin una evaluación de seguridad independiente.

10. Veredicto final

AI-BUSINESS-OS no tiene por qué quedarse como un pasatiempo. Tiene una dirección interesante: convertir la gobernanza de agentes en una infraestructura reutilizable. Pero su futuro comercial no depende de llegar a diez agentes, tener una API documentada o automatizar auditorías diarias.

Depende de resolver tres incógnitas:

1. Fiabilidad: ¿puede demostrar que bloquea lo que debe bloquear y que reanuda correctamente lo que autoriza?
2. Diferenciación: ¿aporta controles que un usuario no obtiene fácilmente configurando Hermes u otro agente existente?
3. Demanda: ¿hay empresas dispuestas a pagar por esa diferencia, y cuánto cuesta atenderlas?

Mi recomendación es mantener el proyecto abierto y experimental mientras se corrige la gobernanza, construir un único piloto y medir sus resultados antes de invertir en una plataforma completa. No vendería todavía garantías de seguridad empresarial.

La apuesta comercial más interesante sería un motor independiente de políticas, aprobaciones y auditoría que pueda trabajar con distintos agentes. Si consigue demostrar esas propiedades y resolver un problema económico real, tendrá una base mucho más sólida para convertirse en un producto.

¿Qué camino querés priorizar ahora?

- A. Seguridad primero: cerrar los defectos técnicos y preparar un prompt de corrección para Codex.
- B. Negocio primero: diseñar un piloto vendible para pymes, con oferta, precios y captación de clientes.
- C. Diferenciación primero: diseñar la arquitectura para integrar AI-BUSINESS-OS con Hermes y convertirlo en una capa de gobernanza multiagente.